

Decision Rationale

Corgi Cyber Protection Policy (CORG-CY-0200) · Sample insured: Cedar Ridge Accounting Group, LLC · September 2026

1. Summary

I wrote one cyber policy for small and mid-sized businesses: firms with a few dozen staff, sensitive client data and a heavy reliance on cloud software. The goal: pay for what actually stops a small firm working, in words an owner can follow mid-incident.

Three choices shape the whole policy:

1. **The firm's own losses are core cover, not add-ons.** Incident response, ransomware, lost income, data restoration and payment fraud sit in every policy alongside liability. A small firm's work stops long before anyone sues. The price is more exposure for the insurer, which the caps in point 2 contain.
2. **Coverage follows what failed.** The firm's own systems, including its cloud accounts, are treated differently from a provider's systems, and attacks differently from accidents. Provider outages and accidents can hit many insureds at once, so they carry their own lower caps. That limits the insurer's exposure without cutting the core.
3. **Honest mistakes don't cost the business its cover.** A failed security control, an honest error in the application or a hotline call as the only notice does not, by itself, take away cover.

Cedar Ridge Accounting Group, a fictional 62-person Denver accounting firm, is the sample insured, and its application fills in the Declarations (the summary page of limits and premium). All premiums, limits and loss figures below are my assumptions for this exercise, not quotes or actuarial results.

2. How I used outside sources

I used three kinds of sources, each for a different job.

- **Existing policies, to learn the standard shape.** I read complete small-business forms from At-Bay, Travelers, DUAL, Coalition and Chubb, following each coverage through its definitions, exclusions and conditions. [1–4, 10] Where they agreed, I kept the market's approach. Where they disagreed, I chose, and this paper says why. Coalition's specimen showed that an endorsement (an add-on page) can quietly change a base rule, so I read those too. [4]
- **Claims reports, to see where losses are heading.** I read At-Bay's InsurSec Report 2026 to see which losses hurt small firms most. [5] Ransomware with downtime, payment fraud and provider outages stood out, so they get the most attention in the policy. I also added cover for newer risks the older forms say little about: deepfake fraud, AI agents acting outside their permissions, and invoice diversion after a hack of the firm's systems.
- **Frameworks and regulatory guidance, to keep it workable.** NIST's small-business guide shaped the application's security questions. [6] Treasury's OFAC advisory set the ransom-payment rules. [11] Travelers' fraud supplement helped with the payment questions. [8]

3. How the policy is built

- Someone reading a cyber policy during an incident wants to know three things: am I covered, what do I pay, and what do I do now. The layout answers them in that order.
- **Guide, Declarations, then the form.** A one-page reading guide explains four terms before the reader meets them: the aggregate (the most the policy pays in a year), a sublimit (a smaller cap inside it), the retention (the firm's deductible) and the waiting period (outage hours the firm absorbs before income cover starts). The Declarations list every coverage by name with its limit and the firm's share, and Item 5 shows how the shared annual pool gets used up. A one-page "Reporting an incident" checklist follows.
 - **Coverages grouped by the problem.** Section I has seven groups: respond to an incident, cyber extortion, recover income, restore data and systems, recover payments, claims against you, and other losses. Every coverage uses the same four headings: *When it applies*, *What we pay*, *Limit and your share* and *Special conditions*. Operating rules follow each group; defense and settlement rules for the liability coverages sit in Section IV.
 - **One letter per coverage, everywhere.** A incident response · B breach costs · C extortion · D own interruption · E provider cyber interruption · F data restoration · G security upgrades · H payment fraud · I–L liability (privacy, regulatory, PCI, media) · M computer replacement · N reputational harm · O cryptojacking and telecom fraud · P accidental provider outage (optional) · Q website tracking (optional). Each letter means the same thing everywhere.
 - **Two triggers.** Lawsuits can arrive years after a breach, so every loss needs one date that ties it to one policy year. For the firm's own losses (A–H, M–P), that date is when the incident is first discovered. Liability (I–L, Q) is "claims-made and reported": the claim must be made in the policy period and reported within 90 days of its end. Section VII, part 1.4 links the two: reporting an incident during the policy period locks later related lawsuits into this policy.
 - **A broad core with two options.** Corgi's startup product sells cover for the firm's own losses as add-ons to liability. [7] I put those losses in the core so a small buyer cannot be underinsured by omission. The trade-off is more exposure for the insurer. Only two risks are optional: accidental provider outages (P), which can hit many insureds at once, and website-tracking liability (Q), which is concentrated in businesses that run advertising pixels.

4. Limits, retention and waiting periods

Term	My choice	Why	What the business keeps
Policy aggregate	\$2,000,000, one annual pool including defense costs	Two clients require \$1 million; the current \$50,000 is far too small. At-Bay's 2025 ransomware claims with an interruption payment averaged about \$510,000 (one insurer's book, including larger firms) [5, pp. 26, 43], so \$1 million covers the average, not a bad year. On a \$1.3 million loss, \$1 million leaves the firm \$300,000 short; \$2 million leaves \$710,000 for the rest of the year.	Losses above \$2 million. A \$3 million option would need pricing and better loss data.

Term	My choice	Why	What the business keeps
Retention (deductible)	\$10,000, one per incident	A firm this size can absorb small bills. Lower would move frequent small losses to the insurer; higher would strain cash. If several retentions could apply, only the largest does.	The first \$10,000 of each incident.
Fast fraud reporting	H retention falls to \$2,500 if reported within 72 hours	Fast reporting improves the chance of getting stolen money back. [5, p. 34] The discount pays owners to call quickly.	\$2,500 instead of \$10,000.
Incident response services (A)	\$25,000 each incident, \$75,000 a year, for the first 7 days; outside the aggregate; no retention. Pre-incident help: \$2,500 a year.	Early expert help limits the damage, and a free call gets owners calling sooner. The caps bound the insurer's cost.	Nothing for the first 7 days, up to the caps.
Waiting periods	8 hours for D and E; 24 hours for P	Eight hours leaves short glitches with the firm but pays early for a real outage. Accidental provider outages can hit many insureds at once, so the firm keeps a full day. Chubb pays extra expense (costs to keep working) from the start [10, p. 17]; I applied the wait to both, so each claim has one start time.	Income and extra expense during the wait.
Accidental system failure (D and F)	\$250,000 shared; full-limit option not selected	Accidents are frequent. The cap pays the base case in the Appendix (\$155,000) but not the stress case (\$298,750).	\$48,750 in the stress case, plus loss during the wait.
Technology-provider cyber interruption (E) / Accidental technology-provider outage (P)	\$500,000 / \$250,000, P purchased	Cedar Ridge has no full substitute for its cloud tax and payroll platforms. One provider failure can hit many insureds at once, so provider limits sit below the aggregate, and accidents lower still.	Provider outage losses above these caps.
Payment and invoice fraud (H)	\$250,000 (options: \$500,000 or \$1,000,000)	About 60 supplier payments a month, usually under \$25,000: \$250,000 covers at least ten typical payments. If a client pays a fake invoice, H pays the firm's cost of the work (no profit), not the invoice total.	A peak transfer above \$250,000.
Period of restoration (how long lost income is paid)	Up to 180 days	Long enough for a recovery that lasts months. Ninety days would stop too early; a year adds exposure without much benefit.	Loss after 180 days.
Smaller caps	G \$25,000 · K \$250,000 · M \$100,000 · N \$100,000 (90 days after a 14-day wait) · O \$50,000 · proof-of-loss help \$50,000 per incident	Each bounds a follow-on loss. Card exposure is modest: \$410,000 a year through a hosted processor, with no card numbers stored. Replacing all 71 laptops and 2 servers at an assumed \$1,800 and \$10,000 each costs \$147,800; M pays \$100,000.	\$47,800 in that full-fleet case, including the retention.

Term	My choice	Why	What the business keeps
Settlement refusal	Firm pays 30% of damages above the refused offer and of later defense costs	Discourages costly refusals while the insurer still pays most of the cost. At-Bay uses 20%. [1, p. 6] Example: refuse \$5,000; costs hit \$30,000; after the \$10,000 retention, insurer pays 70% (\$14,000), firm \$16,000.	30% of costs after the refusal.
Extended reporting (extra time after the policy ends in which new claims about earlier events still count)	60 days automatic; 12 months for 75% or 24 months for 125% of premium	60 free days bridge a short gap; the paid options suit a firm closing or switching insurers. At the \$8,000 sample premium: \$6,000 or \$10,000.	Claims made after the chosen period. The price factors need testing.
Premium	\$8,000 illustrative: \$7,500 core + \$500 for P	Round figures to complete the sample Declarations.	—

5. What I included and what I left out

Included as core cover

- **Breach response costs (B)**, including help for people facing tax-related identity theft. Cedar Ridge holds Social Security numbers and tax records for about 31,000 people, so this is the breach cost its clients are most likely to need.
- **Cyber extortion and ransomware (C)**. The firm never has to pay a ransom to keep its cover. Any payment needs our written consent and a sanctions check, following Treasury's OFAC advisory. [11] Before we consent, the policy also requires a report to the FBI or the Cybersecurity and Infrastructure Security Agency (CISA) unless law enforcement advises otherwise.
- **Data and system restoration (F)** and **security improvement costs (G)**. Upgrades are paid only under G, and only when our response team recommends them in writing, so restoration never becomes a general IT refresh.
- **Payment and invoice fraud (H)**, one of the losses hurting small firms most. [5]
- **Liability (I–L)**: privacy lawsuits, regulatory defense and penalties, Payment Card Industry (PCI) fines and media liability. With tax records for about 31,000 people, a breach at Cedar Ridge brings claims as well as costs.
- **Computer replacement (M)**, **reputational harm (N)** and **cryptojacking and telecom fraud (O)** (outsiders running up the firm's computing or phone bills). Each is a follow-on loss, so each has a small cap.

Optional

- **Accidental technology-provider outage (P): purchased**. Cedar Ridge has no full substitute for its cloud platforms; offline work is only a temporary workaround.
- **Website-tracking liability (Q): not purchased**. The risk is low: Cedar Ridge runs Google Analytics 4 behind a consent banner, with no ad pixels, session replay or chat widget. A banner does not prove compliance, so Q stays on offer and the firm keeps the remaining risk.

Left out on purpose

- **Professional errors** (exclusion 20). A tax-preparation mistake belongs on the firm's \$2 million errors-and-omissions policy. A breach that happens while doing professional work stays covered, and Coverage I defends without waiting for the E&O insurer (Section VII, part 9.2).
- **Deliberate theft by insiders**. It falls outside H, whether a current owner, employee or individual contractor wires money out or diverts a customer's invoice payment. That keeps H as cyber-fraud cover, not employee-dishonesty cover. Cedar Ridge has no crime policy, so this is a real gap, and the application flags it.
- **Tracking and biometric-privacy suits** (exclusion 10). Tracking suits are covered only under Q. Damages set by law per violation can dwarf a small-business premium. A hack that exposes biometric data is still covered.
- **Utility, internet backbone and natural-disaster outages** (exclusions 12 and 13). These cannot be priced into a small-business premium. Under exclusion 12, security failures in the firm's systems, and failures inside a provider's systems under E and P, stay covered. A provider outage caused by fire or flood stays excluded.
- **War and major state-backed cyber operations** (exclusion 15). Ordinary ransomware and fraud by state-linked groups stay covered. Under the state-operation branch, systems outside the country that suffered the major impact stay covered. We carry the burden of proof, and response and defense continue until we prove the exclusion applies.

6. Key definitions

Section V has 60 numbered definitions in alphabetical order, and bold terms in the text link to them. Each definition covers one idea and states its own exceptions, so a reader doesn't have to hunt for a distant exclusion. These six carry the most weight:

Definition	What I decided	Why
Incident (28)	One umbrella term for security failure, system failure, privacy event, cyber extortion, payment fraud, computer fraud and adverse publication. Related events are one incident.	One trigger, one retention rule and one related-events rule work across every own-loss coverage. A ransomware attack that triggers B, C and F costs the firm one \$10,000 retention, not three.
Security failure (53)	Includes stolen or phished credentials, rogue employees, lost devices, and an outsider manipulating an AI agent.	Most small-firm intrusions start with a valid but stolen password. Naming it removes the argument that the login was "authorized."
Cloud accounts (9), Computer systems (12), Dependent systems (18)	The firm's cloud accounts, settings and data are its own systems. The provider's servers, code and network are not.	A hacked Microsoft 365 account is Cedar Ridge's own security failure (D, up to the full aggregate). A Microsoft outage is a provider event (E or P). At-Bay and Travelers also separate the firm's own interruption from a provider's. [1, p. 3; 2, pp. 2, 4, 7, 11]
Payment fraud (37) and Computer fraud (10)	Outside deception or unauthorized system use, including deepfake audio and video. Excludes current owners, employees and individual contractors, and anyone colluding with them.	Keeps H as cyber-fraud cover. Employee theft belongs on a crime policy, a separate kind of insurance.

Definition	What I decided	Why
System failure (56)	An unplanned, accidental outage, including human error, a faulty vendor update or a malfunctioning AI agent. Excludes utilities and public internet infrastructure.	Accidents happen often, and one faulty vendor update can hit many firms, so they get their own cap instead of security failure's full limit.
AI agent (2)	Software that acts without a person approving each step, with a test for when it "exceeds its authority."	AI tools already sit in email and payment workflows. The policy says how they are treated, and Section I confirms that the use of AI alone never excludes a loss.

7. Choices that make the policy usable in a claim

- **A hotline call is notice** (Section VII, part 1.1). DUAL treats its hotline as help only and requires separate formal notice. [3, pp. 3, 15] I made the call count, which means the insurer must record and route every call reliably.
- **No consent needed** to use our pre-approved vendors, make legally required notices, contain an attack in the first 72 hours or settle within the retention (Section VII, part 2.2). In the first hours, speed matters more than approval.
- **Shutting down to contain an attack is covered** (Section I, part 3.3), even when a government agency orders the shutdown; exclusion 14 carves this out. An owner who pulls the plug on good advice should not lose cover for doing the right thing.
- **Security answers are not warranties** (promises that cost the firm its cover if broken; Section III, part 3). A missed callback or a failed backup does not, by itself, reduce a covered payment. I removed security credits and penalties; Coalition's managed-detection credit is a possible later model, but it needs service checks and pricing evidence. [9] The trade-off is more risk for the insurer, so the application checks controls before the policy is issued.
- **Honest application mistakes** (Section VII, part 3.2). We will not rescind (void the policy from the start), and only premium and retention can change, from the date we give notice. Rescission is reserved for an executive's knowing, material misstatement.
- **Full prior acts**: no cut-off date for events before the policy starts. Cedar Ridge has operated since 2009 and is replacing existing cover, so a cut-off would open a gap. Problems the firm already knew about stay excluded, judged as of October 15, 2026, the continuity date.
- **Service standards** (Section VII, part 7). We aim to make contact within one hour and give a coverage decision within 30 days of receiving the documents we ask for. We pay agreed amounts within 15 days, with 8% annual interest when late. Once we confirm D, E or P applies, we advance 50% of the estimated loss within 10 business days, and can use one shared forensic accountant.
- **Fair disputes** (Section VII, part 8). A free internal review, then mediation that we pay for, then court or arbitration.
- **Calling early never counts against the firm at renewal** (Section VII, part 6.2).

8. Three claim tests

Each test assumes unused limits, timely reporting, eligible costs and no other insurance or recoveries. Interruption amounts are after the waiting period.

Event	Result
Ransomware: \$20,000 incident response + \$100,000 breach costs + \$150,000 restoration + \$200,000 lost income = \$470,000	One \$10,000 retention; we pay \$460,000. The \$20,000 of incident response is outside the aggregate, so \$440,000 uses it and \$1.56 million remains . The firm pays \$10,000 plus loss during the 8-hour wait.
Accidental outage of the firm's own systems: \$200,000 lost income + \$100,000 restoration = \$300,000	\$290,000 qualifies after the \$10,000 retention on restoration. The shared accident cap pays \$250,000 ; the firm bears \$50,000 plus loss during the wait; \$1.75 million remains . The accident cap is now used up for the year.
A payroll clerk deliberately steals \$100,000	H pays \$0 ; theft by an employee is neither payment fraud nor computer fraud. The firm bears \$100,000 and the full \$2 million remains. A separate cyber loss caused by an employee can still qualify under other coverages.

Appendix: the income model behind the \$250,000 accident cap

The application gives \$8.1 million prior revenue and \$8.5 million projected revenue. The breakdown below is my assumption.

Annual input	Assumed amount
Pretax profit	\$1,275,000
Payroll that continues during an outage	\$4,800,000
Other continuing costs	\$1,400,000
Costs avoided during an outage	\$1,025,000
Total (matches projected revenue)	\$8,500,000

- **Daily basis.** Profit plus continuing costs is \$7,475,000. Over 260 earning days, that is **\$28,750 a day**.
- **Base case.** Four lost days plus \$40,000 of extra expense: $(\$28,750 \times 4) + \$40,000 = \mathbf{\$155,000}$. This fits within the \$250,000 cap if no restoration claim competes for it.
- **Stress case.** Six days in tax season at 1.5 times the daily basis, plus \$40,000: $(\$28,750 \times 1.5 \times 6) + \$40,000 = \mathbf{\$298,750}$. The cap leaves **\$48,750** with the firm. The 1.5 factor tests sensitivity; it is not a forecast.
- **Recovered work.** In the base case, if \$80,000 of delayed fees is earned later at \$15,000 extra completion cost, the net recovered benefit is \$65,000, and the payment falls to **\$90,000** ($\$115,000 - \$65,000 + \$40,000$).

I kept the \$250,000 cap knowing the stress case exceeds it. Seasonal accounts, recoverable work and available cash could change that choice.

References

Page numbers are PDF viewer pages. These are the editions I compared, not a claim that each is the insurer's current product.

1. **At-Bay, Cyber Insurance Policy** (AB-CYB-001.2, 08/2023 specimen). Used for: own vs. provider interruption (p. 3); the settlement split (p. 6).
2. **Travelers, CyberRisk Coverage** (CYB-16001, 06/2020 sample). Used for: how coverage, systems and providers are separated (pp. 2, 4, 7, 11).
3. **DUAL, Cyber and Data Protection Policy** (North America, "Cyber Wording 2026"). Used for: hotline help vs. formal notice (pp. 3, 15).
4. **Coalition, Oregon specimen policy package** (CYUSP-00PF-1022-01 with endorsements). Used for: how an endorsement can replace base reporting rules (p. 64).
5. **At-Bay, InsurSec Report 2026** (April 2026). Used for: 2025 ransomware costs (pp. 26, 43); fraud reporting and recovery (p. 34).
6. **NIST, CSF 2.0 Small Business Quick-Start Guide** (SP 1300, February 2024). Used for: the application's security questions (pp. 3–8).
7. **Corgi, Cyber Liability Insurance for Startups** (summary of CORG-CY-0100, reviewed April 24, 2026). Used for: comparing how own-loss cover is packaged.
8. **Travelers, Social Engineering Fraud Supplement** (CYB-14301, 01/2019). Used for: payment-control questions (pp. 1–2).
9. **Coalition, Managed Detection and Response, US** (updated August 1, 2024). Used for: security credits as a possible later model.
10. **Chubb, Cyber Enterprise Risk Management** (PF-48169, 02/2019 small-business sample). Used for: waiting period and extra expense (p. 17).
11. **U.S. Treasury / OFAC, Updated Ransomware Advisory** (September 21, 2021). Used for: sanctions checks and reporting before any ransom payment (pp. 1, 3–6).
12. **At-Bay, InsurSec Report 2025**. Background reading; all At-Bay figures cite [5].

Prepared by Rana for the Corgi take-home. This paper explains the accompanying policy; it does not amend its terms.